Setnayan Privacy Manual

> **ADOPTION-READY · 2026-07-24 — formatted for the DPO's signature and NPC filing.**
> Date prepared for adoption: **2026-07-24**
> Document ID: `NPC_Compliance/01_Privacy_Manual_ADOPTED_2026-07-24.md`
> Governing law: Republic Act No. 10173 (Data Privacy Act of 2012), its Implementing Rules and Regulations (IRR), and issuances of the National Privacy Commission (NPC).

> **Revised 2026-10-22 (v1.1) — still ADOPTION-READY; the DPO re-signs § 12.** Measured against the shipped code on `origin/main` (`aceb080a0a`) and the live `/privacy`, `/cookies`, `/terms` and `/refunds` pages. Changes in this revision: the published DPO contact is now **dpo@setnayan.com** (owner ruling 2026-09-22) · **PostHog removed, essential cookies only, no banner** (PR #6774) · first-party **site Visits** (daily aggregates, daily-salted hash) added · **sign-in with Google and Apple** and **Apple in-app purchase (built, switched off)** added · the **supplier Papic capture lane** and the **supplier photo takedown** added · sub-processor table (§ 8.2) rebuilt from the hosts the code actually calls · account deletion (§ 5.3, § 5.5, § 6) re-stated as request → 24-hour admin review → anonymise-and-retain · face-data consent (§ 7) re-stated as an explicit, default-off, adults-only opt-in · the face-data and supplier-upload sweeps marked as built (PR #4735) · `setnayan.ph` struck (we do not own it). See `00_WHAT_CHANGED_2026-10-22.md` and the § 12 version table.

> ### [OK] ADOPTION POSTURE — adopt now, counsel later
>
> This Manual is prepared for the DPO to **adopt as v1.0 now**, on the DPO's own authority — a sole proprietor may adopt their own RA 10173 compliance documents. To adopt: the owner supplies the **6 fields** in the checklist immediately below, signs the approval block in § 12, and sets the effectivity date.
>
> **External Philippine counsel review is recommended, not blocking.** It is not required to adopt this Manual or to file NPC registration. Where counsel or the NPC later requires a change, it is applied by a **dated amendment** (see the § 12 version table); any affected live feature can also be switched off immediately via the in-app Data Privacy control board (`/admin/data-privacy`).
>
> **Two things stay firm before any NPC filing:** (1) the 6 owner fields below must be **real values, not placeholders** — do not file with blanks; and (2) the risk items flagged in the text — especially minors' data (dependents, face matching at christenings/debuts), the automated fraud suspension and the processors with no signed DPA — remain visible and should get a counsel pass when one is engaged. (Updated 2026-10-22 — the vendor gov-ID + AMLC item is resolved: retired 2026-07-03.)

Fields the owner must supply before signing

1. **Barangay + ZIP** for the principal address (76 Sampaguita Avenue, Quezon City — complete it).
2. **BIR TIN / Form 2303 number** — enter this at filing from admin → Compliance; **never write it into this file.**
3. **Exact DPO position/title string** (the precise wording of the DPO's designated title).
4. **A contact phone number** — one mobile suffices; it serves as the PIC contact, DPO contact, and breach hotline.
5. **Which sub-processors have a signed DPA on file.** (!) UPDATED 2026-10-22: the code's own register (`apps/web/lib/subprocessors.ts`) records `dpa_on_file: false` for **every** processor. The "PostHog instance region" question is retired — PostHog was removed on 2026-10-22 (PR #6774).
6. **The adoption / signature date.**

This Privacy Manual is the flagship governance document of the Personal Information Controller. It states how the organization collects, uses, stores, discloses, and disposes of personal data; how it upholds the rights of data subjects; and how it manages security, breaches, and cross-border transfers. It is intended to be kept on file and presented to the NPC on request.

1. Introduction, Purpose & Scope

1.1 The Personal Information Controller (PIC)

Field	Value
Legal entity	**SETNAYAN SOFTWARE DEVELOPMENT SERVICE** — a sole proprietorship of **Indalecio Sacdalan Casasola II**
DTI Business Name Registration	**No. 8297508** (national scope; valid **25 Jun 2026 – 25 Jun 2031**)
Brand	Setnayan
Domains / platform	`setnayan.com` ((!) CORRECTED 2026-10-22 — `setnayan.ph` struck: we do not own it, owner 2026-08-11)
Nature of business	Philippines-first life-events (weddings-first) planning platform serving three roles — customers (couples/organizers), vendors, and guests
Registered address / principal place of business	76 Sampaguita Avenue, Quezon City, **‹OWNER TO SUPPLY: barangay + ZIP›**
Number of employees / personnel with access to personal data	**2 of 2** — Indalecio S. Casasola II (proprietor + DPO) and Claire E. Buanhog (VP, co-founder)
Approximate number of data subjects	(!) **Not re-measured 2026-10-22** (no production access from this session) — read the live count from `/admin/compliance/data-sheet` on filing day. Last measurement: **48 as measured in production 2026-08-17** (9 accounts + 39 guests; 2 shops; 6 events; 0 active biometric face vectors). (!) CORRECTED 2026-08-17 — this field read **~401** from the 2026-07-05 pre-launch snapshot (19 customers + 50 vendors + 332 guests; 61 events). That test data was purged; `07_Compliance_Facts_Register` recorded the ~10× drop on 2026-07-31 and the correction was never propagated to the headline fields. The registration-threshold analysis is UNAFFECTED and strengthened: 48 subjects and 0 biometric vectors sit further below the ≥1,000-SPI trigger than the stale figures did
NPC registration number (PIC/DPO registration)	DPO registered on the NPC DPO system **2026-07-07**; DPS registration reference to be captured after NPCRS filing

1.2 Purpose

This Manual:

- Documents the PIC's personal data processing activities and the safeguards applied to them.
- Serves as the reference for all personnel who process personal data on the PIC's behalf.
- Demonstrates the PIC's accountability and compliance posture to the NPC, to data subjects, and to partners.
- Operationalizes the binding **Setnayan Privacy & Security Policy** (`01_Contracts/Setnayan_Privacy_and_Security_Policy.md`), which every account holder accepts at registration.

1.3 Scope

This Manual applies to **all personal data** processed by the PIC across all systems, personnel, contractors, and sub-processors, in every format (electronic and, where applicable, physical). It covers the personal data of **customers, vendors, and guests**, and the internal personnel data the PIC processes as an employer/engager (2 personnel with personal-data access — see § 1.1).

1.4 Commitment to RA 10173

The PIC commits to upholding the three data privacy principles — **transparency, legitimate purpose, and proportionality** — and to protecting the rights of every data subject. The platform is built on a **privacy-by-design + compliance-by-default** posture: privacy safeguards are engineered into the systems (row-level access control, encryption, per-event scoping) rather than bolted on. The organization's person-graph features are **adults-only**; processing of minors' data and legacy/post-mortem data is a future, counsel-first phase and is **not undertaken now**.

---

2. Definitions

Terms used in this Manual carry the meanings assigned by RA 10173 and its IRR:

Term	Meaning
Personal Information (PI)	Any information from which the identity of an individual is apparent or can reasonably and directly be ascertained, or when put together with other information would directly and certainly identify an individual.
Sensitive Personal Information (SPI)	PI about an individual's race, ethnic origin, marital status, age, colour, religious/philosophical/political affiliations; health, education, genetic or sexual life; any proceeding for any offence; government-issued identifiers (SSS, TIN, etc.); and information specifically established by law as classified.
Privileged Information	Any and all forms of data which, under the Rules of Court and other pertinent laws, constitute privileged communication.
Personal Information Controller (PIC)	A person or organization who controls the collection, holding, processing, or use of personal information — here, SETNAYAN SOFTWARE DEVELOPMENT SERVICE.
Personal Information Processor (PIP)	Any natural or juridical person to whom a PIC may outsource or instruct the processing of personal data (the PIC's sub-processors — see § 8).
Data Subject	The individual whose personal information is processed — Setnayan's customers, vendors, and guests.
Processing	Any operation performed upon personal data — collection, recording, organization, storage, updating, retrieval, consultation, use, consolidation, blocking, erasure, or destruction.
Consent	Any freely given, specific, informed indication of will by which the data subject agrees to the processing of personal data about them.
Data Protection Officer (DPO)	The individual designated by the PIC to be accountable for compliance with RA 10173.

Personal Data Breach	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data.

---

3. Governance & Organizational Structure

3.1 Data Protection Officer (DPO)

Field	Value
Designated DPO	**Indalecio Sacdalan Casasola II**
DPO position / title	**‹OWNER TO SUPPLY: exact DPO position/title string›**
DPO contact	**dpo@setnayan.com** (published on every legal page — owner ruling 2026-09-22, `apps/web/lib/contact-addresses.ts`) · **‹OWNER TO SUPPLY: contact phone number (serves PIC + DPO + breach hotline)›**. (!) UPDATED 2026-10-22 — this read iscasasolaii@gmail.com, which is still the address on the NPC DPO-system registration of 2026-07-07; update that registration to dpo@setnayan.com at NPCRS filing so the two agree.
NPC DPO registration	Registered on the NPC DPO system **2026-07-07**; DPS registration reference to be captured after NPCRS filing

The DPO is the organization's accountable officer for data privacy and the single point of contact for data subjects and for the NPC. The DPO's responsibilities include:

- Monitoring and ensuring the PIC's compliance with RA 10173, its IRR, NPC issuances, and this Manual.
- Serving as the contact point for data subject requests and complaints (access, rectification, erasure, objection, portability, and breach inquiries).
- Overseeing the conduct of Data Privacy Impact Assessments (DPIAs — see § 10) and maintaining the DPIA register.
- Leading the security incident and breach response process (see § 9), including NPC and data-subject notification.
- Cultivating a privacy-aware culture through personnel training and periodic review of policies.
- Reviewing and advising on sub-processor engagements and cross-border transfers.

3.2 Security Measures — Overview

The PIC maintains organizational, physical, and technical security measures proportionate to the nature of the personal data processed and the risks involved. The measures below summarize the controls already in place per the binding Privacy & Security Policy.

3.2.1 Organizational measures

- **Binding policy acceptance.** Every customer, vendor, and guest accepts the Privacy & Security Policy at registration; acceptance is logged with timestamp, IP, and user-agent in a `policy_acceptances` record per user.
- **Role-based responsibility.** Internal (admin) access is gated to granular roles; each role can only reach the surfaces it is permitted.

- **Two-admin approval** for high-impact actions — role provisioning, brand-configuration changes, refunds above PHP 10,000, and unlimited-use grants above PHP 10,000 retail value.
- **Confidentiality obligations** on personnel and contractors — **‹OWNER TO ADOPT: short signed confidentiality note + basic-hygiene policy recommended›**.
- **Privacy training** for personnel who process personal data — **‹OWNER TO ADOPT: short signed confidentiality note + basic-hygiene policy recommended›** (training cadence to be set with the same policy).

3.2.2 Physical measures

- **No self-hosted data centre.** The PIC does not operate physical servers; personal data resides with managed cloud processors (Supabase, Cloudflare) under their physical-security controls and data-processing agreements.
- Access to workstations and administrative credentials is restricted to authorized personnel — **‹OWNER TO ADOPT: short signed confidentiality note + basic-hygiene policy recommended›** (device/endpoint hygiene to be set with the same policy).

3.2.3 Technical measures

Control	Implementation
Access control (deny-by-default)	Row-Level Security (RLS) on the Postgres database — every query is gated so no client can read another user's row. Deny-by-default is the baseline; access is granted only by explicit policy.
Encryption in transit	TLS 1.3 on all external connections and WebSocket channels; HSTS enabled in production; mixed content blocked.
Encryption at rest	AES-256 on the database and object storage; keys managed by the cloud providers' key-management services. Face vectors are stored as event-scoped rows in the encrypted Postgres database (`guest_face_enrollments.face_vector`), under the same RLS deny-by-default gate as all other personal data — *not* in a separate object-storage index (corrected 2026-07-31; see § 5.3).
Authentication	E-mail + password (hashed by Supabase Auth, never plaintext), an e-mailed sign-in link, or Sign in with Google / Apple (each behind a switch). Cloudflare Turnstile bot check on sign-up / sign-in forms when its key is set. (!) **CORRECTED 2026-10-22 — two statements here were not true in code:** there is **no mobile + OTP sign-in** (no SMS in V1), and **no two-factor authentication is built** — `origin/main` contains no MFA / TOTP enrolment or `aal2` check, so it is neither offered to users nor mandatory for admins. Admin access rests on the password plus server-side role checks (`is_admin()`). Building admin 2FA is an open security item.
Session management	The Supabase sign-in cookie lasts up to 1 year (longer in the installed app; until the browser closes if "Stay signed in" is off), per `/cookies`. (!) CORRECTED 2026-10-22 — this read "30-day inactivity expiry", which the shipped cookie does not do. Switching between several accounts on one phone (PR #6784) is **not shipped** (PR open, not merged, 2026-10-22).

Short-lived media access	Object storage is private; access is via short-lived signed URLs (5 minutes for sensitive media). No public reads.
Application hardening	Input validation at every entry point; parameterized queries (no SQL injection); output escaping + CSP (no XSS); CSRF tokens on state-changing requests; rate limiting on auth endpoints.
Audit logs	Every admin action is logged append-only (no UPDATE permission) with timestamp, actor, action type, target entity, before/after state, and rationale.
Backups	**NONE — there are no automated database backups.** The database runs on the Supabase FREE plan, which provides no scheduled snapshots, and no backup job of our own exists — the platform's ~16 cron-free periodic jobs are application sweeps, none of which is a database backup. (!) CORRECTED 2026-08-17 — this row previously declared "Daily encrypted database backups retained 30 days", which was never true. Owner ruling 2026-08-10 (*"let's stay free for the moment"*) records the absence of backups as a CONSCIOUSLY ACCEPTED cost, to be revisited before launch; the paid tier would give daily backups with 7-day (not 30-day) retention. Encryption at rest, TLS 1.3 in transit and RLS isolation are unaffected and remain in force.

---

4. Data Processing Principles Applied

The PIC applies the three RA 10173 principles to every processing activity:

4.1 Transparency

Data subjects are informed of the nature, purpose, and extent of processing before or at collection. Mechanisms:

- Registration-time acceptance of the Privacy & Security Policy (logged per user).
- A published privacy notice on `setnayan.com/privacy` (last updated 2026-10-22), a cookie list on `setnayan.com/cookies` (essential cookies only, no banner) and a Google-access summary on `setnayan.com/privacy/google-access`. (!) CORRECTED 2026-10-22: there is **no** `/privacy/changelog` page and the live notice has no "changes to this policy" section; the 30-day notice + re-consent commitment is the adopted rule, not yet reflected on the public page (open item in `00_WHAT_CHANGED_2026-10-22.md`).
- The DPO's contact (**dpo@setnayan.com**) is published on `/privacy`, `/terms`, `/refunds`, `/cookies` and `/acceptable-use` as the channel for questions and rights requests. (Updated 2026-10-22 — was the owner's personal mailbox.)

4.2 Legitimate Purpose

Processing is limited to declared, specified, and legitimate purposes and is never incompatible with them. Concrete examples:

- **Service delivery** — providing the planning tools, gallery, RSVP, and vendor-matching a customer contracts for (basis: performance of contract / legitimate interest).
- **Payments** — apply-then-pay reconciliation using **reference data only**; no card, CVV, or full bank-account numbers are stored (basis: performance of contract).
- **Vendor verification** — business-document review (DTI, BIR 2303, Mayor's Permit, bank proof, portfolio, references) and a 15-minute Google Meet identity call at onboarding (bases: consent, legitimate interest). (!)

CORRECTED 2026-10-22: no government ID, no liveness check and no AML sanctions screening — those were retired 2026-07-03, so the AMLA basis is struck.

- **Face auto-tagging** — matching a guest to their own photos, per-event only, on **explicit, separate, default-off consent, adults 18+ only** (basis: consent, §13(a)). (Corrected 2026-10-22 — "implied" struck; the shipped opt-in is a separate checkbox and enrolment refuses a known minor, `app/papic/face-enroll-actions.ts`.)

4.3 Proportionality

Only data adequate, relevant, and necessary to the declared purpose is processed:

- **Payment data minimization** — reference and receipt data only, never full credentials.
- **Per-event face scoping** — face vectors are generated and used **per event only, never reused across weddings**, and are deleted with the event data. There is **no cross-event face recognition**.
- **Person-graph minimization** — connections require **mutual confirmation**; cross-person visibility is **name-only**; extended relationships are **derived, never stored**; trusted-circle signals are **aggregated/computed (≥5 minimum), never per-person records**.

---

5. Data Lifecycle: Collection → Use → Storage → Disclosure → Disposal

5.1 Collection

Personal data collected, by role:

Role	Categories collected
Customer (couple/organizer)	Full name, mobile, email, optional profile photo; optional religion / civil status / birth date / dietary needs (each consent-stamped); event details (date, venue, target pax, role, ceremony type); payment **reference/receipt** data and proof screenshots (no full credentials); dependents' details for christenings and milestones (entered by the parent); uploaded content (photos, invitation customizations); chat messages with vendors/coordinators; sign-in identity from Google or Apple where chosen.
Vendor	Business + identity documents (DTI Business Name Certificate, BIR Form 2303, Mayor's Permit, government ID, bank-account proof, portfolio, client references, live selfie + liveness); service profile; payout account and transaction history; behavioral data; chat messages. Includes **SPI** (government-issued identifiers).
Guest	Full name, mobile, optional profile photo; event linkage and role; RSVP status, dietary needs, table assignment; captured/tagged photos and clips; QR-scan records (IP truncated; the guest may switch them off); optional push-notification subscription. (!) Updated 2026-10-22: **the RSVP no longer asks guests for e-mail and guests receive no e-mail** (owner 2026-09-29).
Face vectors (special category)	Per-event face vectors computed **in the guest's browser** from a selfie taken after a separate, default-off consent tick (adults 18+ only), used only to find that guest's photos within that one event. (Corrected 2026-10-22 — the RSVP-photo / kiosk description was the old design.)

5.2 Use

Primary uses: providing contracted services, vendor matching, payment processing, per-event photo auto-tagging, event/payment notifications, and aggregated admin reporting. **There is no product-analytics service** (PostHog removed 2026-10-22, PR #6774); site traffic is counted first-party as daily aggregates with a salted hash that is destroyed each day (ROPA DPS-21), with no cookie. Secondary uses (anonymized aggregate improvement/ML, marketing samples, promotional communications) require **separate, revocable consent**. Personal data is **never sold**, never used for external targeted advertising, and never shared with government except as required by Philippine law (subpoena/court order).

5.3 Storage, Residency & Retention

System	Location	Content
Database (Postgres)	**Supabase — Singapore**	PII + transactional data, RLS-gated, AES-256 at rest. **Includes the biometric face vectors** — `guest_face_enrollments.face_vector` (JSONB) and `user_face_profiles` (corrected 2026-07-31, see note)
Object storage	**Cloudflare R2 — APAC region**	Photos/videos, the **source selfie images** for face enrolment, vendor verification documents; private + signed-URL access

> ** Corrected 2026-07-31 — where the biometric data actually sits. **This table previously placed a *"per-event encrypted face-vector index"* on Cloudflare R2.** Verified against shipped code, that is not how it was built. **The face vectors are `JSONB` columns in** Supabase Postgres (Singapore) **— `guest_face_enrollments.face_vector` (migration `20260901000000`) and the account-level descriptor in `user_face_profiles` (migration `20270306508746`). R2 holds the** source selfie image **(`guest_face_enrollments.asset_url` = `r2://…`), not the vector.** No R2 vector index exists. **Both locations are outside the Philippines, so § 10's cross-border conclusion is unchanged — but the NPC registration sheet asks *where sensitive personal information resides*, and biometric data is the most scrutinised category, so the location must be stated accurately. Same correction applied to `02_Records_of_Processing_Activities` DPS-04 and `03_DPO_Designation_and_NPCRS` § sub-processors.**
> **| Email |** Resend** | Transactional/notification email delivery |

Representative retention windows (full table in the Privacy & Security Policy § 4):

Data type	Retention	Deletion trigger
Customer/vendor account profile	Active	**Deletion request → admin review within 24 hours → erasure at once (anonymise-and-retain, § 5.5).** (!) CORRECTED 2026-10-22 — this read "Account deletion + 30-day grace then purge"; no grace period and no scheduled purge exist in code (finding #6 of 2026-08-24). (!) The live `/privacy` retention table still says "a short 30–90 day tail" and `/terms` says "30 days" — both are open copy fixes (`00_WHAT_CHANGED_2026-10-22.md`).

Customer event data	**Kept for the LIFE OF THE ACCOUNT**, deleted when the couple closes or deletes their account. Owner ruling 2026-08-17. ((!) CORRECTED 2026-10-22: "plus the existing 30-day tail" struck — no tail exists in code.) (!) **CORRECTED — the previous "5 years post-event, auto-purge at T+5y" rule is WITHDRAWN, not merely unbuilt.** Building it as written would have DELETED THE PHOTOS: in the live schema the photo rows, the guest list, the tags, the schedule and the supplier list all cascade from the event, so removing a wedding removes its album — contradicting the owner's twice-locked rule that no photo is ever deleted, only compressed. Retention is therefore bound to the purpose that is still running (the couple's own album and its context) rather than to a timer, matching the treatment of account data. Any future end date must be built to remove planning details WITHOUT touching the photos.	Deleted with the account
Photo/video originals	Full-resolution ORIGINAL: the later of 6 months from the event's first capture and 3 months after the event ENDS (the celebration's last day: `event_end_date` where the event spans several days, else `event_date` — owner 2026-08-10), then **replaced by** a compressed web copy. **Compressed web copy: free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** No scheduled deletion at any point. **No photo is ever deleted on a schedule.** Disposal occurs only on organizer removal, a validated erasure request, or account deletion. Originals synced to the couple's own Google Drive are theirs permanently and are never touched.	(!) **CORRECTED 2026-08-07.** This row previously declared a **5-year hard limit** with 90-day-hot/5-year-cold tiering. That tiering was never built, no R2 lifecycle rule exists, and the compressed copy is kept indefinitely — so the row committed us, in a filing, to destroying photos we in fact keep. Declaring a purge that never happens is the more dangerous direction of drift: a commitment to the regulator broken every day.

Face vectors	[OK] **UPDATED 2026-10-22: the selfie, enrolment and vector are erased when the event's Papic closes, 12 hours after the event ends** (owner 2026-09-30, *"face will be only saved for that day"*, PR #6195). Backstop: **deleted 3 MONTHS AFTER THE EVENT ENDS** (`event_end_date` where the celebration spans several days, else `event_date`) — owner ruling 2026-08-17. Earlier deletion any time via the guest's "Delete my face data" link or Photo Consent OFF (≤ 5-minute revocation), which DO work today. [OK] **UPDATED 2026-10-22 — ENFORCEMENT IS BUILT:** PR #4735 (merged 2026-08-23) added the 3-month face-data sweep and the 90-day supplier-upload sweep; the qualifier "ENFORCEMENT NOT YET BUILT" that these rows carried from 2026-08-17 is no longer true. The sweeps are cron-free (they run on request traffic), so their timing depends on traffic; that they have run against production data was not verified from this session. (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one. **Deleting face data does NOT remove photo tags** — verified in the live schema: a tag carries the guest link itself and has no reference to face data, so nothing cascades. Guests keep every photo already delivered; only FUTURE automatic matching is lost, which is why the 3-month mark is safe. (!) CORRECTED 2026-08-17 — this row previously declared a "per-event lifetime + 5 years, auto-purge with event data" rule, which nothing implemented — and which had silently become "never deleted" when the media row moved to indefinite retention on 2026-08-02.	Revoke link works today

Vendor verification audit trail / permits	(!) **CORRECTED 2026-08-24 — THE COLLECTION THIS ROW DESCRIBES WAS RETIRED 2026-07-03; it now governs LEGACY uploads made before that date, not an ongoing collection.** Raw uploads (government ID, selfie + liveness video, bank micro-deposit, portfolio): **deleted 90 DAYS AFTER the approve/reject decision** — owner ruling 2026-08-17, which makes true the promise this row already made. The DECISION RECORD ONLY (outcome, deciding admin, timestamp, screening result) is retained **7 years** (BIR §235 + AMLC AML/CTF). DTI / BIR 2303 / Mayor's Permit: 7 years. Transaction history: 5 years (policy §4). [OK] **UPDATED 2026-10-22 — ENFORCEMENT IS BUILT:** PR #4735 (merged 2026-08-23) added the 3-month face-data sweep and the 90-day supplier-upload sweep; the qualifier "ENFORCEMENT NOT YET BUILT" that these rows carried from 2026-08-17 is no longer true. The sweeps are cron-free (they run on request traffic), so their timing depends on traffic; that they have run against production data was not verified from this session. (!) **CORRECTED 2026-08-17 (same day):** an earlier revision of this row said *"production has ZERO scheduled jobs, so no automatic deletion of any kind runs today"* — **that was wrong.** Setnayan deliberately runs **cron-free**: a database compare-and-swap claim fired from request traffic drives **~16 periodic jobs**, all verified running on 2026-08-17, and several DO delete automatically (a 5-year chat purge, a 180-day Deep-Search-dossier purge, an anonymous-draft sweep, and the full-resolution photo replacement). The gap is that **no job covers THIS class yet** — not that the machinery is absent. Stating the period alone would replace a false promise with a newer one.	BIR § 235 + AMLC AML/CTF
Chat messages / audit logs	5 years	Aligned with event / tax-legal retention
Anonymized aggregate data	Indefinite (no PII)	Not auto-purged

5.4 Disclosure / Sharing

Disclosure is limited to the sub-processors in § 8, each engaged under a data-processing agreement and used only for the declared purpose. Internal (Setnayan Team) access to event media is read-only, case-scoped to mediation, and never bulk-exported.

5.5 Disposal

Disposal occurs by automated sweep at the retention boundary (where a sweep exists — see § 5.3) or on a validated deletion request. **Account deletion is anonymise-and-retain, not a cascade** ((!) CORRECTED 2026-10-22 — the previous text described a cascade, which the code does not do; finding #16 of 2026-08-24): an admin approves the request, then `eraseUserAccount` blanks the person's own personal fields (name, contact details, photo, optional profile details), removes their face data and device hashes, revokes a Sign in with Apple grant, and keeps the **anonymised** business records other people rely on (a supplier's reviews and statistics, an event's ledger, BIR receipts, which are kept for their statutory period). The code docstring states this is deliberate: erasure must destroy the personal data, not other people's business records. Known gap: the name/e-mail/avatar copy that Google sign-in leaves in the sign-in provider's identity record (`auth.identities.identity_data`) is not yet blanked (DECISION_LOG 2026-10-22) — an open engineering item.

---

6. Data Subject Rights

Every data subject has the following rights under RA 10173. All are exercised by contacting **dpo@setnayan.com** (and, for several, via in-app settings surfaces).

#	Right	How to exercise / PIC response
1	**Right to be informed**	Via this Manual, the published privacy notice, and registration-time disclosures.
2	**Right to access**	Request a copy of personal data held, via dpo@setnayan.com. **Response: within 15 business days** for non-urgent requests.
3	**Right to object**	Opt out of specific data uses (e.g., marketing samples, promotional email) via settings or dpo@setnayan.com.
4	**Right to rectification**	Edit profile in-app; request corrections via dpo@setnayan.com.
5	**Right to erasure or blocking**	Profile → "Delete my account" → type DELETE. An admin reviews within **24 hours** (active events, bookings, balance) and erasure runs on approval — anonymise-and-retain per § 5.5, with statutory-retention exceptions. ((!) CORRECTED 2026-10-22 — was "confirmed within 30 days; cascade".) A guest may also ask for a photo of them to be taken down — including a **supplier's own copy and portfolio** (owner ruling 2026-09-16, shipped as TD-1) — and may withdraw face-matching consent at any time.
6	**Right to damages**	File a complaint with the NPC for violations; the PIC cooperates with any NPC proceeding.

7	**Right to data portability**	Profile → download a JSON archive (`/api/profile/export`); photos via the album ZIP download. Raw face vectors are excluded from the export. (!) Known gap (DECISION_LOG 2026-09-16): the export omits several record types; not yet fixed.
8	**Right to be notified**	Notification of any breach affecting the subject's data, per § 9.

Person-graph specific rights: a data subject may decline connection requests, remove confirmed connections, hide individual life-story items per-person (without affecting the host's gallery), and opt out of an event's story entirely; deletion cascades to their connections and story-item references.

---

7. Consent Management

- **Registration consent.** Acceptance of the Privacy & Security Policy is captured and logged (timestamp + IP + user-agent) at account creation.
- **Face detection.** (!) CORRECTED 2026-10-22 — the "implied consent by uploading an RSVP photo" description was the old design. Today a guest ticks a **separate, default-off** box (*"face recognition for this wedding"*), confirms they are **18 or older**, and only then takes a selfie; the server refuses a vector without that consent and refuses a guest the host has marked as a minor, and stamps the time, source and consent-copy version. The guest can withdraw at any time; withdrawal deletes the face data and, since PR #4747 (2026-08-24), **blurs the guest's face and keeps the photo** (owner ruling 2026-08-17 — one guest opting out does not delete a table's group shot). Blur applies on the venue wall, the shared pool and the public event page; the couple's own album is unblurred. Face processing is **per-event only**.
- **Vendor verification consent.** Vendors give explicit, itemized consent at registration for DTI lookup, third-party ID/liveness verification, portfolio reverse-image search, reference calls, and AMLC sanctions screening. [OK] **STATUS CONFIRMED 2026-08-24, AND IT RESOLVES THE FLAG AS "NOT A STUB — REMOVED".** These slots were **retired by the owner on 2026-07-03**; identity confirmation is a 15-minute Google Meet. **No third-party ID/liveness verification and no AMLC screening is consented to, requested, or performed.** The itemized consent must not ask for them.
- **Marketing samples.** Use of a customer's renders/captures as marketing samples requires a **separate written opt-in**, revocable at any time; existing materials are removed within 90 days of revocation.
- **Person graph.** Connections require **mutual confirmation** (no one-sided edges); life-story items rely on existing event photo-consent and are individually hide-able/opt-out-able; trusted-circle recommendations are aggregate-only.
- **Withdrawal.** Consent may be withdrawn at any time through settings or dpo@setnayan.com, without affecting the lawfulness of prior processing.
- **Material changes** to processing carry 30 days' advance notice and a re-consent prompt at next login where the change affects data use.

---

8. Data Sharing, Sub-Processors (PIPs) & Cross-Border Transfers

8.1 Hosting & cross-border disclosure

The PIC's primary infrastructure is hosted **outside the Philippines**: the database in **Singapore** (Supabase) and object storage in the **APAC region** (Cloudflare R2). Routine application operations therefore involve **cross-border**

processing. All such transfers are encrypted in transit (TLS 1.3), governed by the providers' data-processing agreements, and remain subject to NPC oversight; the PIC remains accountable for personal data transferred to any processor.

8.2 Sub-processors (Personal Information Processors)

> **Rebuilt 2026-10-22 from the hosts the shipped code actually calls** (`origin/main` `aceb080a0a`: every `fetch` host, SDK and CSP entry), not from earlier documents. Where a service only runs once a key or a switch is set, that is stated; **whether each key or switch is set in production cannot be read from the code and was not verified.** The code's own register (`apps/web/lib/subprocessors.ts`) records **no signed DPA with any processor** (`dpa_on_file: false` on every row).

Sub-processor	Jurisdiction	Data shared	Purpose	Runs when
Supabase	Singapore	All structured personal data (accounts, guests, events, orders, chat), **including the biometric face vectors**	Database, sign-in, realtime	Always
Vercel	US company; app functions pinned to Singapore (`vercel.json` `sin1`)	Every request in transit — IP, headers, request bodies	Application hosting	Always
Cloudflare	R2 storage: Asia-Pacific (APAC). Relay / bot check: global network	**R2:** photos, videos, enrolment selfies, payment-proof screenshots, supplier documents, chat files. **TURN relay:** call and camera media and the IP address, in transit only. **Turnstile:** the visitor's IP and browser signals on sign-in / sign-up forms. **STUN:** the device IP	Storage; live-video relay; bot check	R2 always; TURN and Turnstile only when their keys are set
Resend	United States	Recipient e-mail, subject, message body	Transactional e-mail	When the e-mail key is set
Sentry	United States	Error stack traces and breadcrumbs; on a browser error, a **masked** screen replay (all text masked, all media blocked); e-mails, phone numbers and face vectors are scrubbed before sending; `sendDefaultPii` off	Error monitoring	When the DSN is set (production)

Anthropic	United States	Payment-receipt screenshots (to read the reference typed); a supplier's own public business information (Deep Search); supplier mood-board gallery photos (to catch logos / contact details); a couple's theme sentence; supplier category requests; admin search phrases	AI assistance — **never** approves a payment, never trains on our data	When the API key is set
OpenAI	United States	Text of a couple's event story / editorial and of guest-written columns	Content moderation	When the API key is set
LanguageTool (LanguageTooler GmbH)	Germany (EU)	The same editorial text, sent to the free public API	Spelling and grammar check	Always, when an editorial is scanned — **no DPA, free public endpoint** (open owner decision since 2026-08-24)
Google	United States	**Sign-in:** name and e-mail. **YouTube (Live Watch):** OAuth tokens, broadcast details. **Drive:** event photos copied into the couple's own Drive (`drive.file`). **Gemini:** mood-board pictures on a paid render. STUN: device IP	Sign-in; live broadcast; photo delivery; image render	Sign-in behind `NEXT_PUBLIC` YouTube / Drive only after the user connects; Gemini only on a paid render

Apple	United States	**Sign in with Apple:** Apple ID token (name, e-mail — possibly a private-relay address); the refresh token is kept so the grant can be revoked on erasure. **In-app purchase:** signed App Store transactions and Apple's server notifications, verified offline. **iTunes search:** the song search term and the visitor IP	Sign-in; iOS purchases; song previews	Sign-in behind `NEXT_PUBLIC` **in-app purchase built but switched off** (`NEXT_PUBLI` default off)
Meta (Facebook, Instagram)	United States	Setnayan's own promotional posts; a supplier's own Instagram posts after the supplier connects	Social publishing; supplier Instagram sync	Only with the page token / after a supplier connects; Facebook sign-in switched off
TikTok	Singapore / United States	OAuth tokens, the rendered video, post details	Patiktok posting	Only after the user connects
OpenStreetMap (Nominatim + map tiles)	United Kingdom (OSM Foundation) — not verified	A venue or shop address typed in; the viewer's IP for map tiles	Address → map pin; maps	When an address is placed on a map
Vimeo	United States	A supplier's Vimeo link	Video poster image	Only for Vimeo links
Browser push services (Apple / Google / Mozilla)	Browser vendor	Notification title, body and link	Web push notifications	When push keys are set and the user allows notifications

Public CDNs (jsDelivr, unpkg, Google storage)	Global	The visitor's IP only	Downloading the face-check and video-compression libraries	When those features run
~~Persona / Veriff / Onfido~~ · ~~AMLC API / ComplyAdvantage~~	—	—	[X] **NOT SUB-PROCESSORS — retired 2026-07-03, struck 2026-08-24.** No relationship, no data ever sent.	
~~PostHog~~	—	—	[X] **REMOVED 2026-10-22 (PR #6774)** — no analytics SDK, no analytics cookie, no consent banner.	
Suno	—	—	**Not called by the code** (a team member uses it by hand to make music; no personal data). Not a sub-processor.	

Payments are not a processor relationship. Customers pay by manual transfer to Setnayan's own GCash / BDO accounts and upload a proof; an admin matches it by hand. The code calls **no** payment API (PayMongo, Maya, Stripe and GCash/BDO APIs are not called). The proof screenshot reaches only R2 and, when its key is set, Anthropic.

Face matching has no outside processor. Face descriptors are computed in the guest's browser (and, for the one end-of-event rescan, by the same open model inside our own Vercel function); the model files are self-hosted. No face data is sent to any AI company.

All non-ASEAN sub-processors are to be bound by Standard Contractual Clauses (SCCs) or equivalent data-processing agreements. (!) **CORRECTED 2026-10-22: none is signed yet** — this is NPC filing task `t2-8`. **‹OWNER TO SUPPLY: which sub-processors have a signed DPA on file›.**

---

9. Security Incident & Personal Data Breach Management

The PIC maintains a documented incident-response and breach-management process. Summary posture:

- **Detection & assessment.** Incidents are assessed by the DPO and response team to determine whether a **personal data breach** has occurred and its severity.
- **NPC notification.** Where the breach is notifiable, the NPC is notified **within 72 hours** of knowledge/confirmation, consistent with RA 10173 and NPC Circular 16-03.
- **Data-subject notification.** Affected data subjects are notified **within 72 hours** (in-app + email) of what data was involved, when, remedial actions taken, and recommended protective steps.
- **Public disclosure.** A breach summary is posted on the site within 7 days where appropriate. (!) CORRECTED 2026-10-22: no `setnayan.com/security` page exists yet; the summary would be published on `/privacy` or a new page at the time. The live `/privacy` page does not yet state the breach-notification promise (open copy item).
- **DPO channel.** Breach inquiries go to **dpo@setnayan.com**; a hotline (**‹OWNER TO SUPPLY: contact phone number (serves PIC + DPO + breach hotline)›**) is used for high-severity incidents.
- **Records.** All incidents and responses are documented for the mandatory breach report and NPC review.

> The full procedure — response team, severity matrix, containment/eradication/recovery steps, notification templates, and the breach register — is maintained in the **Data Breach Management Policy**: `NPC_Compliance/04_Data_Breach_Management_Policy_ADOPTED_2026-07-24.md` (corrected 2026-10-22 — this pointed at the superseded draft).

---

10. Data Privacy Impact Assessments (DPIA)

The PIC conducts a **DPIA** before undertaking any processing that is likely to pose a risk to the rights and freedoms of data subjects — in particular new features involving sensitive or high-volume personal data (e.g., face vectors, the person graph, vendor identity verification, and any future minors/legacy processing). Each DPIA identifies data flows, risks, and mitigations, and is reviewed by the DPO before the processing goes live.

> The DPIA methodology and the register of completed/pending assessments are maintained in: `NPC_Compliance/05_DPIA_Register_DRAFT_2026-07-05.md`.

Minors' data and legacy/post-mortem processing are **not undertaken now**; when contemplated, each will be **counsel-first** and gated on a dedicated DPIA and guardian-consent/post-mortem mechanics.

---

11. Inquiries, Complaints & NPC Contact

- **Data subject inquiries and complaints** are directed to the DPO at **dpo@setnayan.com**. The DPO acknowledges and responds within the timelines in § 6, coordinates rectification/erasure/objection, and maintains a record of complaints and their resolution.
- **Escalation to the NPC.** A data subject who is not satisfied may lodge a complaint with the **National Privacy Commission**:

> National Privacy Commission
> 5th Floor, Philippine International Convention Center (PICC) Complex, Vicente Sotto St., Pasay City, Metro Manila 1307
> Email: info@privacy.gov.ph · Website: privacy.gov.ph
> `[TO CONFIRM current NPC address/contact at time of filing]`

---

12. Review, Version Control & Effectivity

- **Ownership.** This Manual is owned by the DPO (Indalecio Sacdalan Casasola II) and approved by the PIC (Indalecio Sacdalan Casasola II).
- **Review cadence.** Reviewed at least **annually**, and additionally upon any material change to systems, sub-processors, or applicable law/NPC issuances.
- **Change control.** Material changes to processing are communicated to data subjects per § 7 and § 11 of the Privacy & Security Policy (30 days' notice; re-consent where required; public changelog).
- **Effectivity.** This Manual takes effect upon (a) the owner supplying the six fields in the "Fields the owner must supply before signing" checklist and (b) sign-off by the DPO/PIC below with an effectivity date. External PH counsel review is **recommended, not a precondition**; any change counsel or the NPC later requires is applied by a **dated amendment** (version table below). Until the owner fields are supplied and the block is signed, this Manual is **not yet adopted** and should not be filed.

Version	Date	Author	Status

0.1 (DRAFT)	2026-07-05	Prepared for DPO/counsel review	Not yet adopted
1.0 (Adoption-ready)	2026-07-24	Formatted for DPO signature	Pending owner fields + signature (counsel review recommended, non-blocking)
1.0 corrections	2026-08-17 / 2026-08-24	DPO-directed corrections	Backups, retention, photo lifetime, vendor verification, Vercel/Sentry/LanguageTool
1.1 (Revised)	**2026-10-22**	Refresh against `origin/main` `aceb080a0a`	DPO contact → dpo@setnayan.com; PostHog removed / essential cookies only; Visits; Google + Apple sign-in; Apple in-app purchase (off); supplier capture lane + takedown; sub-processor table rebuilt; deletion = anonymise-and-retain; face consent explicit + 18+, selfie erased 12 h after the event; sweeps built; no 2FA; `setnayan.ph` struck. **Still unsigned — the DPO signs v1.1 (not v1.0).**
Adopted	**‹OWNER TO SUPPLY: adoption date›**	Indalecio Sacdalan Casasola II (DPO)	Effective on signature (after owner fields; counsel review recommended, applied by amendment)

Approval blocks (to be completed on adoption):

Sign this version (v1.1, revised 2026-10-22).

- PIC / Owner: Indalecio Sacdalan Casasola II — Signature: __ Date: _____
- DPO: Indalecio Sacdalan Casasola II — Signature: __ Date: _____

> **Footnote.** This document was drafted to a compliant RA 10173 baseline **ahead of counsel** to accelerate finalization. It **is not a substitute for legal review**, and external Philippine counsel review is **recommended** — but per the adoption posture above it is **not a precondition** to adoption or filing; any change counsel or the NPC later requires is applied by a **dated amendment**. Before filing, the DPO (Indalecio Sacdalan Casasola II) should still confirm every remaining owner-supplied fact is a real value and confirm each sub-processor's DPA status (§ 8.2). The identity-verification / sanctions-screening question is resolved (retired 2026-07-03; revised 2026-10-22).